

open-provenance: An Open, Offline, User-Governed System for Verifiable Media Provenance and Durable Recovery

Abu Sufian Sarkar
abu@cyberdude.com

June 14, 2026

Abstract

The marginal cost of producing convincing synthetic images, audio, and video has fallen to near zero, eroding society’s shared ability to answer a basic question: *did this actually happen?* We argue that the tractable response is not universal *detection* of synthetic media—which the literature shows to be brittle and adversarially fragile—but verifiable *provenance*: cryptographically signed, content-bound statements about how a piece of media came to be. We present **open-provenance**, an open-source system built on the C2PA standard that makes provenance verification (i) *offline*, requiring no network and no trusted third party at verification time; (ii) *user-governed*, so that the decision of *whom to trust* rests with the verifier rather than a central gatekeeper; and (iii) *honest*, with a conservative verdict model that never conflates an intact provenance chain with the truth of the depicted events, and never treats the absence of provenance as evidence of fabrication. We further study the central weakness of metadata-based provenance—that it is stripped by screenshots and social-media re-encoding—and prototype a *durable* recovery layer combining a perceptual-fingerprint registry with robust watermarking. On a controlled synthetic benchmark, fingerprint-based recovery perfectly separates genuine from unregistered content after aggressive transport (resize to 70% and JPEG quality 40; ROC AUC = 1.0; mean Hamming distance 0.33 vs. 21.67 of 64 bits), while a lightweight frequency-domain watermark survives recompression only down to JPEG quality ≈ 70 and fails by quality 30, motivating learned watermarks for the embedded path. We are explicit about scope: the open ecosystem cannot read proprietary watermarks (e.g. SynthID), so durable recovery protects content that passes through participating signers, not arbitrary third-party media. All code, the evaluation harness, and this report are released openly.

1 Introduction

Generative models now synthesize photorealistic media indistinguishable from captured reality [14]. This is not a niche concern: the ability to attribute media to a source underpins journalism, legal evidence, scientific record, elections, and ordinary interpersonal trust. Two broad technical responses exist. *Detection* asks a classifier whether a given artifact is synthetic; it is a moving target, content- and model-specific, and degrades under distribution shift and adversarial post-processing [9, 17]. *Provenance* instead attaches verifiable, signed statements to media at creation and edit time, shifting the question from “does this look fake?” to “what is this artifact’s documented history, and do I trust the party that attests to it?”

We take the provenance position, and observe that a provenance system intended as shared infrastructure must satisfy three properties that existing deployments only partially meet. First, **verification must be a public good**: it should require no account, no gatekeeper, and—critically—no network, so that a journalist in the field or a court clerk can verify locally. Second, **trust must be**

user-governed: a verifier that ships a fixed list of “legitimate” signers is itself a central arbiter of authenticity, which is precisely the concentration of power a neutral system should avoid. Third, the system must be **epistemically honest**: it must distinguish “the cryptographic chain is intact” from “the depicted events are true,” and must never present the mere absence of provenance as evidence of manipulation.

Contributions.

1. An open verifier with a conservative, formally specified verdict and trust model that encodes the honesty properties above (§4), realized as both an offline CLI and a zero-backend in-browser WebAssembly application.
2. A user-governed trust mechanism in which the verifier cryptographically validates the signer’s certificate chain against anchors the *user* supplies, with no built-in default trust list (§4).
3. A study and open prototype of *durable* provenance recovery—surviving metadata stripping—combining a perceptual-fingerprint registry with robust watermarking, with a reproducible evaluation (§6).
4. An explicit threat model and an honest account of what open provenance can and cannot do, including the proprietary-watermark gap (§3, §7).

2 Background and Related Work

Provenance standards. The C2PA specification [3] defines a *manifest*: a set of assertions about an asset (capture device, edits, ingredients) bound to the asset’s pixels by cryptographic hashes, and signed using a COSE structure [16] whose signer is identified by an X.509 certificate chain [6], optionally timestamped via RFC 3161 [1]. The Content Authenticity Initiative [4] promotes adoption (“Content Credentials”). The IPTC `digitalSourceType` vocabulary [12] provides the standard marker for algorithmically generated media (`trainedAlgorithmicMedia`).

Watermarking. Classical invisible watermarking embeds a payload in transform coefficients (DWT/DCT/SVD) [7, 13]; such methods survive mild recompression and scaling but are fragile under strong compression and geometric distortion. Learned watermarks embed and detect payloads with neural networks and are markedly more robust: Stable Signature roots a watermark in a diffusion model’s decoder [10]; TrustMark targets arbitrary-resolution robustness for C2PA soft binding [2]; WAM localizes messages and resists cropping [15]; SynthID is a widely deployed but proprietary scheme [8, 11].

Fingerprinting. Perceptual hashes summarize low-frequency image structure into compact codes stable under recompression and scaling [18], enabling content matching against a registry. The combination of robust watermark, fingerprint, and manifest registry is the basis of “durable” Content Credentials [5].

3 Threat Model

Goals. For a verifier V presented with an asset a , the system should provide (G1) *integrity*—detect any modification of a after signing; (G2) *authenticity of the signer*—establish, relative to V ’s chosen trust anchors, which party signed a ; (G3) *recoverability*—when a ’s manifest has been stripped, recover it for content previously registered by a participating signer.

Adversary. We consider an adversary who may: strip or alter manifest metadata; recompress and rescale (lossy transport via screenshots and social platforms); crop or geometrically distort; substitute or self-sign with an attacker-controlled certificate (forge signer identity); and replay a valid manifest onto different content. The adversary does *not* possess the private keys of signers V trusts, and cannot break the underlying signature or hash primitives.

Non-goals. The system does *not* establish that the events depicted in a are true (a correctly signed photograph may still be staged), does *not* detect unmarked synthetic media, and does *not* read third-party proprietary watermarks. The absence of provenance is treated as *uninformative*, never as evidence of fabrication.

4 System Design

4.1 Honest verdict model

Given the validation outcome of a C2PA read, the verifier emits exactly one verdict $\in \{\text{VERIFIED}, \text{NO_CREDENTIALS},$

- **VERIFIED:** a manifest is present and all signature and content-hash checks pass. This asserts chain integrity only.
- **NO_CREDENTIALS:** no manifest is present. Formally uninformative about authenticity.
- **INVALID:** a manifest is present but a hash or signature check fails; the asset was altered after signing or the chain is broken.

Orthogonally, the verifier reports a trust status $\in \{\text{TRUSTED}, \text{UNTRUSTED}, \text{UNCHECKED}\}$. Let C be the signer’s certificate chain and $\mathcal{A}$ the user’s set of trust anchors. Then

$$\text{trust}(C, \mathcal{A}) = \begin{cases} \text{TRUSTED} & \text{if } C \text{ chains to some anchor in } \mathcal{A}, \\ \text{UNTRUSTED} & \text{if } \mathcal{A} \neq \emptyset \text{ and } C \text{ does not,} \\ \text{UNCHECKED} & \text{if } \mathcal{A} = \emptyset \text{ (or no trust engine).} \end{cases}$$

Crucially, **VERIFIED** is independent of trust: a cryptographically valid signature from an untrusted (e.g. self-signed) party yields $\langle \text{VERIFIED}, \text{UNTRUSTED} \rangle$, which the interface presents as a warning, never as an endorsement.

4.2 Offline verification and user-governed trust

Because the signer’s certificate travels inside the manifest, verification is *permissionless* and *local*: no network is contacted. The in-browser implementation disables remote-manifest fetching and OCSP, guaranteeing that no request leaves the device. Trust is supplied by the user as a set of PEM anchors; the toolkit validates C against $\mathcal{A}$ on-device. The system ships *no* default trust list, by design: adopting a published list (e.g. the C2PA list) is the user’s explicit choice, not an imposed policy.

4.3 Durable recovery layer

Metadata-based provenance is fragile: most platforms strip C2PA manifests. We therefore register, at signing time, a mapping from a robust descriptor of the content to its manifest. Two descriptors are used. A *perceptual fingerprint* $\phi(a) \in \{0, 1\}^{64}$ (a DCT perceptual hash) supports registry lookup by nearest Hamming distance; recovery declares a match iff $\min_e \text{Ham}(\phi(a'), \phi_e) \leq \tau$ for

a threshold τ , framing recovery as a detection problem with an ROC over τ . An optional *robust watermark* embeds a short identifier directly in pixels, giving a self-contained pointer that needs no registry. The recovered manifest is then re-verified by the normal offline path.

5 Implementation

The verifier is implemented twice over a single shared, dependency-free verdict classifier: a Node.js CLI using `c2pa-node`, and a zero-backend browser application that compiles the C2PA toolkit to WebAssembly so verification runs client-side and offline. A signing tool emits manifests (optionally tagging generative content via `digitalSourceType`). The durable layer is implemented in Python over a DWT-DCT-SVD watermark [13] and a DCT perceptual hash [18], with a registry supporting `register` and `recover`. The evaluation harness (§6) regenerates every quantitative claim in this report from a single command.

6 Evaluation

Methodology. We evaluate on a controlled synthetic corpus of distinct, smooth images (sums of low-frequency sinusoids), which isolates transport robustness from content variation. We caution that synthetic content is favorable to perceptual hashing and somewhat adversarial to frequency-domain watermarking; evaluation on natural-image benchmarks is future work (§10). All results below are produced by `eval/durable_eval.py` and are fully reproducible.

E1: watermark robustness. We embed a 64-bit identifier and measure the bit-error rate (BER) and exact-recovery rate after JPEG recompression and rescaling (Table 1). The watermark is essentially lossless down to JPEG quality ≈ 70 (exact recovery ≥ 0.96), degrades at quality 50 (BER ≈ 0.03 – 0.07 , exact recovery ≤ 0.12), and collapses at quality 30 (BER ≈ 0.40 , i.e. near random). This confirms that lightweight frequency-domain watermarking is insufficient for social-media-grade transport and motivates learned schemes [2, 15] for the embedded path.

E2: durable recovery. We register 24 images, then issue *genuine* queries (each registered image transported by resize-to-70% plus JPEG quality 40) and *stranger* queries (24 unregistered images under the same transport). Genuine queries match their correct entry at mean Hamming distance $0.33/64$; strangers sit at mean distance $21.67/64$, a wide separation. Sweeping the decision threshold τ yields the ROC in Figure 1 with AUC = 1.0; at the operating point $\tau = 10$ we obtain a true recovery rate of 1.0 at a false-match rate of 0.0. Recovery thus succeeds after a transport that destroys the watermark (Table 1, $q = 40$ regime), validating the fingerprint registry as the robust primary path.

7 Discussion

The asymmetry of provenance is its defining property: *signing is opt-in, verification is universal*. Only content a creator chose to sign carries credentials, but anyone may verify it without permission. This makes “no credentials” the common case in the wild and is why honest messaging matters. Our results also delineate the open ecosystem’s boundary. Robust pixel watermarks deployed by major generative services (e.g. SynthID) are detectable *only* with proprietary, key-gated detectors; the open system cannot recover a stripped third-party asset’s provenance. Durable recovery here

Table 1: E1: watermark bit-error rate and exact-recovery rate vs. JPEG quality and rescale factor (24 images per condition).

JPEG q	scale	mean BER	exact-recovery rate
95	1.00	0.000	1.00
95	0.85	0.000	1.00
95	0.70	0.000	1.00
95	0.60	0.000	1.00
85	1.00	0.000	1.00
85	0.85	0.000	1.00
85	0.70	0.000	1.00
85	0.60	0.000	1.00
70	1.00	0.000	1.00
70	0.85	0.001	0.96
70	0.70	0.000	1.00
70	0.60	0.001	0.96
50	1.00	0.032	0.12
50	0.85	0.057	0.00
50	0.70	0.067	0.00
50	0.60	0.073	0.00
30	1.00	0.382	0.00
30	0.85	0.395	0.00
30	0.70	0.405	0.00
30	0.60	0.406	0.00

therefore protects content that passes through *participating* signers—a meaningful but bounded guarantee, and an argument for open, interoperable robust-watermarking standards.

8 Limitations and Ethics

Results are on a synthetic corpus and are indicative, not a natural-image benchmark. The fingerprint path requires prior registration and is a fuzzy match; at scale it needs collision handling and a registry whose governance is itself a non-gatekeeping design problem. Offline revocation is unhandled: a revoked-but-still-chaining certificate currently reads as trusted. Ethically, the system is designed against two failure modes: over-trust (presenting an untrusted or merely-valid signature as endorsement) and the “liar’s dividend” (treating missing provenance as proof of fakery); both are explicitly precluded by the verdict model. Registries of fingerprints carry privacy implications that a deployment must address.

9 Reproducibility

All artifacts—verifier, signer, durable registry, and the evaluation harness that produced Table 1 and Figure 1—are released under the Apache-2.0 license. Numbers are regenerated by `python3 eval/durable_eval.py`; library versions and random seeds are pinned in the repository.

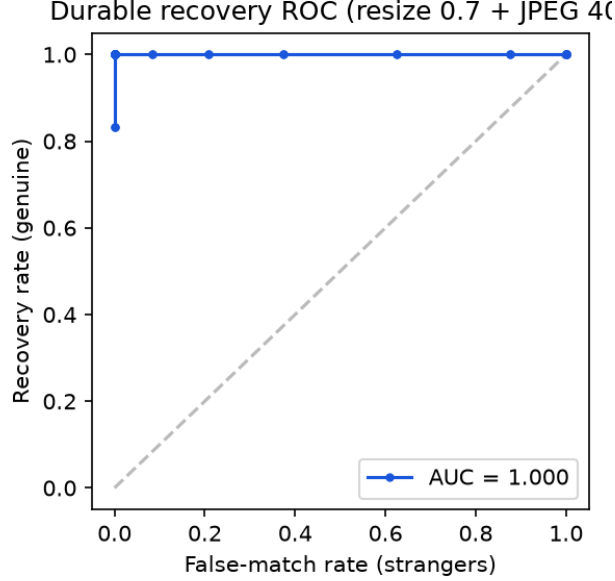


Figure 1: E2: ROC for fingerprint-based recovery (genuine vs. stranger queries) under resize-0.7 + JPEG-40 transport. AUC = 1.0 on the synthetic corpus.

10 Future Work

Natural-image and video benchmarks; integration of a learned watermark (TrustMark/WAM) [2, 15] for screenshot- and crop-robust embedded identifiers; offline revocation and trust-list distribution without a central authority; a decentralized, privacy-preserving recovery registry; and standardization of an open robust-watermark soft binding to close the third-party gap.

References

- [1] C. Adams, P. Cain, D. Pinkas, and R. Zuccherato. Internet X.509 Public Key Infrastructure Time-Stamp Protocol (TSP). Technical Report RFC 3161, IETF, 2001.
- [2] Tu Bui, Shruti Agarwal, and John Collomosse. TrustMark: Universal watermarking for arbitrary resolution images. In *arXiv preprint arXiv:2311.18297*, 2023.
- [3] Coalition for Content Provenance and Authenticity. C2PA technical specification. <https://c2pa.org/specifications/>, 2024. Accessed 2026.
- [4] Content Authenticity Initiative. Content credentials and the CAI. <https://contentauthenticity.org/>, 2024. Accessed 2026.
- [5] Content Authenticity Initiative. Durable content credentials. <https://contentauthenticity.org/blog/durable-content-credentials>, 2024. Accessed 2026.
- [6] D. Cooper, S. Santesson, S. Farrell, S. Boeyen, R. Housley, and W. Polk. Internet X.509 Public Key Infrastructure Certificate and Certificate Revocation List (CRL) Profile. Technical Report RFC 5280, IETF, 2008.

- [7] Ingemar J. Cox, Matthew L. Miller, Jeffrey A. Bloom, Jessica Fridrich, and Ton Kalker. *Digital Watermarking and Steganography*. Morgan Kaufmann, 2nd edition, 2008.
- [8] Sumanth Dathathri et al. Scalable watermarking for identifying large language model outputs. *Nature*, 634:818–823, 2024.
- [9] Hany Farid. *Photo Forensics*. MIT Press, 2016.
- [10] Pierre Fernandez, Guillaume Couairon, Hervé Jégou, Matthijs Douze, and Teddy Furon. The stable signature: Rooting watermarks in latent diffusion models. In *Proceedings of the IEEE/CVF International Conference on Computer Vision (ICCV)*, 2023.
- [11] Google DeepMind. SynthID: Identifying AI-generated content. <https://deepmind.google/technologies/synthid/>, 2024. Accessed 2026.
- [12] IPTC. Photo metadata: Digital source type NewsCodes. <http://cv.iptc.org/newscodes/digitalsourcetype/>, 2023. Accessed 2026.
- [13] Shield Mountain and contributors. invisible-watermark: A python library for invisible image watermarking (DWT-DCT). <https://github.com/ShieldMnt/invisible-watermark>, 2021. Accessed 2026.
- [14] Robin Rombach, Andreas Blattmann, Dominik Lorenz, Patrick Esser, and Björn Ommer. High-resolution image synthesis with latent diffusion models. In *Proceedings of the IEEE/CVF Conference on Computer Vision and Pattern Recognition (CVPR)*, 2022.
- [15] Tom Sander, Pierre Fernandez, et al. Watermark anything with localized messages. In *arXiv preprint arXiv:2411.07231*, 2024.
- [16] J. Schaad. CBOR Object Signing and Encryption (COSE): Structures and Process. Technical Report RFC 9052, IETF, 2022.
- [17] Luisa Verdoliva. Media forensics and DeepFakes: An overview. *IEEE Journal of Selected Topics in Signal Processing*, 14(5):910–932, 2020.
- [18] Christoph Zauner. Implementation and benchmarking of perceptual image hash functions. In *Master’s thesis, Upper Austria University of Applied Sciences*, 2010.